PHASE 2

VULNERABILITY ASSESSMENT & PENETRATION TESTING

Metasploitable 2 • Local Virtual Lab

Prepared by

ANA KABRA

IqraSec Academy — Phase 2 Task
Assessment date: 24–25 October 2026
Target: 10.0.2.3 (Metasploitable 2)

1. Executive Summary

This report documents an initial vulnerability assessment of an intentionally vulnerable Metasploitable 2 virtual machine from a Kali Linux testing VM. The work recorded network/service enumeration, an FTP backdoor detection result, HTTP server metadata, and baseline interaction with the DVWA training application. The assessment was performed for educational purposes within the authorized lab described by the task.

The strongest observed result is that Nmap's ftp-vsftpd-backdoor script reported the target as vulnerable and displayed root-level identity output. This report distinguishes that script output from a separately established interactive shell; the available screenshots do not establish that a persistent or interactive session was opened.

2. Objective and Scope

- Objective: practise local lab deployment, reconnaissance, service enumeration, vulnerability identification, evidence capture, and remediation reporting.
- In-scope target: Metasploitable 2 at 10.0.2.3, as observed during testing.
- Observed services/apps: FTP TCP/21, HTTP TCP/80, phpMyAdmin, and DVWA.
- Out of scope: public IPs, third-party systems, and any system not explicitly authorized for this lab.

Network note: both VMs were reported as NAT. The target address 10.0.2.3 was used in scans; complete VirtualBox isolation was not independently verified.

3. Lab Environment and Tools

- Attacking VM: Kali Linux
- Target VM: Metasploitable 2
- Virtualization: Oracle VirtualBox
- Target address used: 10.0.2.3
- Tools: Nmap, Metasploit Framework, curl, Firefox, DVWA

4. Methodology

- Confirm target reachability in the local lab.
- Enumerate services and versions using Nmap.
- Run a targeted Nmap check for the vsftpd 2.3.4 backdoor signature.
- Inspect HTTP headers, page title, and advertised methods.
- Access phpMyAdmin and DVWA and record visible behavior.
- Test DVWA baseline inputs 1, 2, and abc at displayed High security.
- Capture evidence and distinguish observations from confirmed exploitability.

5. Findings

Finding 1 — vsftpd 2.3.4 backdoor detection

Severity: Critical potential, subject to confirmation of exact build and reproducibility.
Service: FTP, TCP/21 on 10.0.2.3.

Evidence: Nmap's ftp-vsftpd-backdoor script screenshot reports the service as vulnerable/exploitable and shows uid=0(root) gid=0(root). This indicates the script reported root-level command execution during the test. Metasploit module information and a banner-based check were also captured.

Impact: if the vulnerable backdoor is present and reachable, an unauthenticated remote attacker may obtain root-level command execution and potentially fully compromise the host.

Recommendation: remove the affected build, install a trusted supported version, restrict FTP exposure, prefer encrypted file transfer, verify package integrity, and inspect for unauthorized changes.

Verification limitation: evidence does not establish a separately opened interactive shell. Do not claim a persistent shell unless separately demonstrated.

Finding 2 — Legacy HTTP server and version disclosure

Severity: Informational to Medium pending verification.
Evidence: HTTP scan/header screenshots show Apache/2.2.8 (Ubuntu), DAV/2, PHP/5.2.4-2ubuntu5.10, and HTTP 200 OK.

Impact: old software may contain known vulnerabilities, and version disclosure can assist targeting. Version strings alone do not prove a specific exploitable CVE.

Recommendation: upgrade Apache/PHP to supported releases, remove unnecessary modules, minimize excess version detail, and verify patch status.

Finding 3 — phpMyAdmin configuration warning

Severity: Informational pending configuration review.
Evidence: phpMyAdmin page was accessible and displayed a warning that the mcrypt extension could not be loaded.

Impact: this suggests legacy/incompatible extension configuration and may affect functionality; it does not prove database compromise.

Recommendation: upgrade phpMyAdmin and dependencies, correct/remove obsolete extension configuration, and restrict administrative access.

Finding 4 — DVWA baseline testing

Severity: Not rated as a vulnerability from available evidence.
Evidence: DVWA login succeeded using lab credentials; security level displayed High. Input 1 returned admin admin; input 2 returned Gordon Brown; input abc produced no visible record or error.

Assessment: these results demonstrate baseline behavior only. The screenshots do not prove successful SQL injection or unauthorized data extraction. No SQL injection vulnerability is claimed.

Recommendation: keep DVWA isolated; in production use parameterized queries, server-side validation, least-privilege database accounts, and safe error handling.

6. Evidence Index

The Screenshots folder contains supplied images copied into this submission package where available. Check each image and filename before submitting. Supporting raw text evidence expected from Kali includes ftp_check.txt, http_check.txt, http_headers.txt, http_methods.txt, and full_scan.txt only if actually generated.

- 07_DVWA_Login.png
- 06_Metasploit_Module_Info.png
- 05_phpMyAdmin_Warning.png
- 01_Nmap_or_Initial_Scan.png
- 02_FTP_Check_Evidence.png
- 03_HTTP_Enumeration.png
- 04_HTTP_Methods.png
- 08_DVWA_Baseline_1.png
- 09_DVWA_Baseline_2.png
- 10_DVWA_Invalid_Input.png
- 11_DVWA_Security_Level.png
- 12_HTTP_Headers.png
- 13_DVWA_SQLi_Page.png
- 14_Metasploit_Check_or_Info.png
- 15_DVWA_Baseline_Additional.png

- 16_DVWA_Additional.png
- 17_Terminal_Evidence.png

7. Limitations

- Report is based on screenshots and results described during the lab session; raw scan files were not available for independent validation during report creation.
- VirtualBox isolation settings were not independently inspected.
- FTP root-level output is documented, but a separate interactive shell was not established in reviewed evidence.
- No exploitability claim is made for version disclosure, phpMyAdmin warning, or DVWA SQL injection without further evidence.

8. Conclusion

The lab covered service discovery, targeted vulnerability detection, HTTP metadata review, and baseline web-application interaction. The most significant recorded result is the Nmap-reported vsftpd backdoor behavior. Other observations are leads for verification rather than confirmed exploitable vulnerabilities.

9. Remediation Summary

- Replace vulnerable vsftpd 2.3.4 and restrict FTP; prefer secure transfer.
- Upgrade unsupported Apache, PHP, and phpMyAdmin components.
- Correct obsolete extension configuration and limit administrative access.
- Use parameterized queries and least-privilege database permissions in production.
- Maintain isolation for vulnerable training machines.